Dwell Time and Lateral Movement: A Survey of Graph-Theoretic Evasion Strategies

Shreyas R, Karthik SK, Adithyan A, Department of Computer Science and Engineering
JAIN Deemed-to-be University, Bangalore, Karnataka

Abstract, ***Lateral movement strategies are often designed to strategically exceed legal discovery windows. Most privacy laws require notification within 72 hours of discovery; however, if lateral movement is sufficiently slow and mimics administrative tasks, the "dwell time" can be extended indefinitely. This systematic literature review (SLR) categorizes movement techniques based on Dijkstra's Algorithm and Alert-Risk Weighting (ARW). We analyze the dwell-time of attackers in enterprise networks across 50+ case studies drawn from IEEE Xplore, ACM Digital Library, ScienceDirect, and Springer Nature, published between 2019 and 2026. The survey highlights the mathematical relationship between "path stealth" and "legal notification latency," quantifying how graph-theoretic evasion models translate directly into prolonged regulatory non-compliance windows. The taxonomy developed covers four dimensions: credential-based techniques, Living-Off-the-Land (LotL) attacks, protocol tunneling, and slow-burn time-delayed campaigns. A comparative synthesis is conducted across detection accuracy, computational overhead, false-positive rates, and dwell-time distributions. The paper examines legal implications under the GDPR (Articles 5, 25, 32, and 33) and India's Information Technology Act (2000). We conclude by identifying a critical need for laws that explicitly account for stealthy, long-term persistence in data breaches, alongside a future roadmap emphasizing adaptive detection, explainable AI, and federated learning.***

Index Terms — Lateral movement, Dwell time, Graph-theoretic evasion, Dijkstra's Algorithm, Alert-Risk Weighting, APT detection, Living-Off-the-Land, Cyber law, GDPR, Legal notification latency, Enterprise network security, Graph Neural Networks.

I. Introduction

The sophistication of modern cyber adversaries has grown to the point where breach detection and response frameworks embedded in law are routinely outpaced by attacker methodology. Among the most insidious attack strategies is lateral movement — the technique by which a threat actor, once inside a network perimeter, traverses internal systems methodically to escalate privileges, exfiltrate data, or establish persistent footholds. Unlike initial-access exploits that often generate detectable noise, lateral movement is designed to be slow, mimetic, and indistinguishable from legitimate administrative behavior.

Regulatory frameworks such as the General Data Protection Regulation (GDPR) and India's Information Technology Act (2000) impose strict breach notification timelines, often mandating disclosure within 72 hours of discovery. The definition of "discovery" remains legally ambiguous and organizationally variable, creating a critical gap that sophisticated attackers can exploit. By calibrating their movement speed, tool selection, and behavioral footprint to avoid triggering detection thresholds, adversaries can extend dwell time from days into weeks, months, or even years — with documented cases exceeding 280 days in financial and healthcare sectors [7].

Graph theory provides a natural and powerful modeling language for this problem. Enterprise networks can be abstracted as weighted directed graphs where nodes represent hosts, accounts, or services, and edges represent reachable pathways weighted by detection risk. Lateral movement then becomes an optimization problem: finding the path through the network that minimizes cumulative alert probability while maximizing access. Algorithms such as Dijkstra's shortest-path method and its variants have been adapted in the security literature to model both attacker traversal and defender detection strategy [6].

Despite growing research into both lateral movement detection and dwell-time analysis, the literature remains fragmented. Studies in machine learning, graph analytics, cyber law, and incident response rarely synthesize across these domains. This survey bridges that gap through a PRISMA-guided systematic literature review of 54 peer-reviewed papers published between 2019 and 2026, offering a unified taxonomy, comparative analysis, legal mapping, and future research roadmap.

The paper is organized as follows: Section II defines the problem statement and research objectives. Section III details the PRISMA methodology. Section IV covers the

mathematical foundations of graph-theoretic evasion. Section V presents the taxonomy. Section VI provides comparative analysis. Section VII examines legal implications. Section VIII identifies open challenges, and Section IX concludes.

II. Problem Statement and Research Objectives

A. Problem Statement

Enterprise networks are inherently complex graphs of interconnected nodes — workstations, servers, domain controllers, databases, and cloud services — linked by trust relationships, shared credentials, and open service ports. A threat actor with an initial foothold in such a network faces a graph traversal optimization problem: how to navigate from the point of entry to high-value assets while minimizing the probability of detection at each step.

Most legal regimes define the beginning of the breach notification window as the moment of "discovery" — when the organization becomes aware of the breach. If an attacker can remain undetected by mimicking legitimate administrative behavior, the discovery event is indefinitely deferred. This transforms dwell time from a purely technical concern into a legal liability. Research consistently shows that organizations suffering long dwell-time breaches face compounded costs: the breach itself, forensic investigation, regulatory fines for delayed notification, and reputational damage [7], [32].

Current detection systems rely on alert thresholds and anomaly scores calibrated against baseline traffic. Attackers who understand these thresholds — and modern APT toolkits are increasingly designed with this awareness — can design lateral movement campaigns that remain perpetually below detection levels. Living-Off-the-Land (LotL) techniques, which use native OS tools like PowerShell and WMI rather than custom malware, are a prime example: they generate artifacts that are structurally indistinguishable from routine administrative operations, reducing per-step behavioral anomaly scores to near zero [43], [46].

The research gap is threefold: (1) technical — existing detection mechanisms are insufficient against slow, mimicry-based lateral movement; (2) legal — existing cyber law frameworks do not adequately account for attacker-induced discovery latency; and (3) conceptual — no unified framework links graph-theoretic evasion models to their legal notification consequences. This survey addresses all three dimensions.

B. Research Objectives

The specific research objectives are:

1. To systematically review peer-reviewed literature on lateral movement, dwell-time analysis, and graph-theoretic evasion strategies using the PRISMA framework.
2. To formalize Dijkstra's Algorithm and Alert-Risk Weighting as mathematical models for attacker traversal optimization in enterprise network graphs.
3. To develop a four-category taxonomy of lateral movement techniques organized by their stealth mechanism and legal notification impact.
4. To quantify the mathematical relationship between Path Stealth Score (PSS) and Legal Notification Latency (LNL) under regulatory frameworks including the GDPR and India's IT Act (2000).
5. To conduct a comparative synthesis of 40 peer-reviewed detection approaches across detection accuracy, false-positive rate, average dwell time detected, and regulatory exceedance.
6. To identify open research challenges and propose a future roadmap combining adaptive detection, explainable AI, and international legal harmonization.

III. Systematic Literature Review Methodology (PRISMA)

This study employs a Systematic Literature Review (SLR) approach guided by the PRISMA (Preferred Reporting Items for Systematic Reviews and Meta-Analyses) framework. PRISMA ensures a reproducible, transparent, and bias-minimized selection process. The review covers literature published between January 2019 and March 2026 to reflect the most current developments in lateral movement detection, graph-based security analytics, and cyber law compliance.

A. Data Sources and Search Databases

The search covered the following major academic databases:

- IEEE Xplore Digital Library — primary source for cybersecurity, intrusion detection, and network security conference and journal papers.
- ACM Digital Library — primary source for systems security, graph algorithms, and privacy-oriented computing.
- ScienceDirect (Elsevier) — primary source for computer networks, information security, and AI-driven detection.

- Springer Nature Link — supplementary source for information security journals and conference proceedings.
- PubMed Central (PMC) — supplementary source for open-access cybersecurity survey papers.

B. Search Query and Boolean String Formulation

A Boolean search query was constructed to capture the intersection of lateral movement, graph-theoretic modeling, dwell-time analysis, and cyber law compliance:

```
("lateral movement" OR "dwell time" OR "APT detection") AND
("graph theory" OR "Dijkstra" OR "shortest path" OR "graph neural network") AND
("enterprise network" OR "intrusion detection" OR "Living off the Land") AND
("cyber law" OR "GDPR" OR "breach notification" OR "legal compliance")
```

C. Inclusion and Exclusion Criteria

Inclusion Criteria*:*

7. Peer-reviewed journal articles or conference papers published from 2019 to 2026.
8. Studies directly addressing lateral movement detection, dwell-time analysis, or graph-based network traversal modeling.
9. Research applying machine learning, graph neural networks, or optimization algorithms to intrusion detection or APT analysis.
10. Studies that include experimental evaluation with measurable metrics (detection rate, false-positive rate, or dwell-time analysis).
11. Legal and regulatory analyses of breach notification obligations under GDPR, IT Act, NIS2, or comparable frameworks.

Exclusion Criteria:

12. Non-peer-reviewed sources: blogs, vendor whitepapers, or opinion articles.
13. Studies unrelated to lateral movement, dwell time, or enterprise network evasion.
14. Publications lacking experimental validation or legal analysis.
15. Duplicate records across databases.
16. Research focused on domains (e.g., network routing optimization without security context) that do not contribute to the survey's objectives.

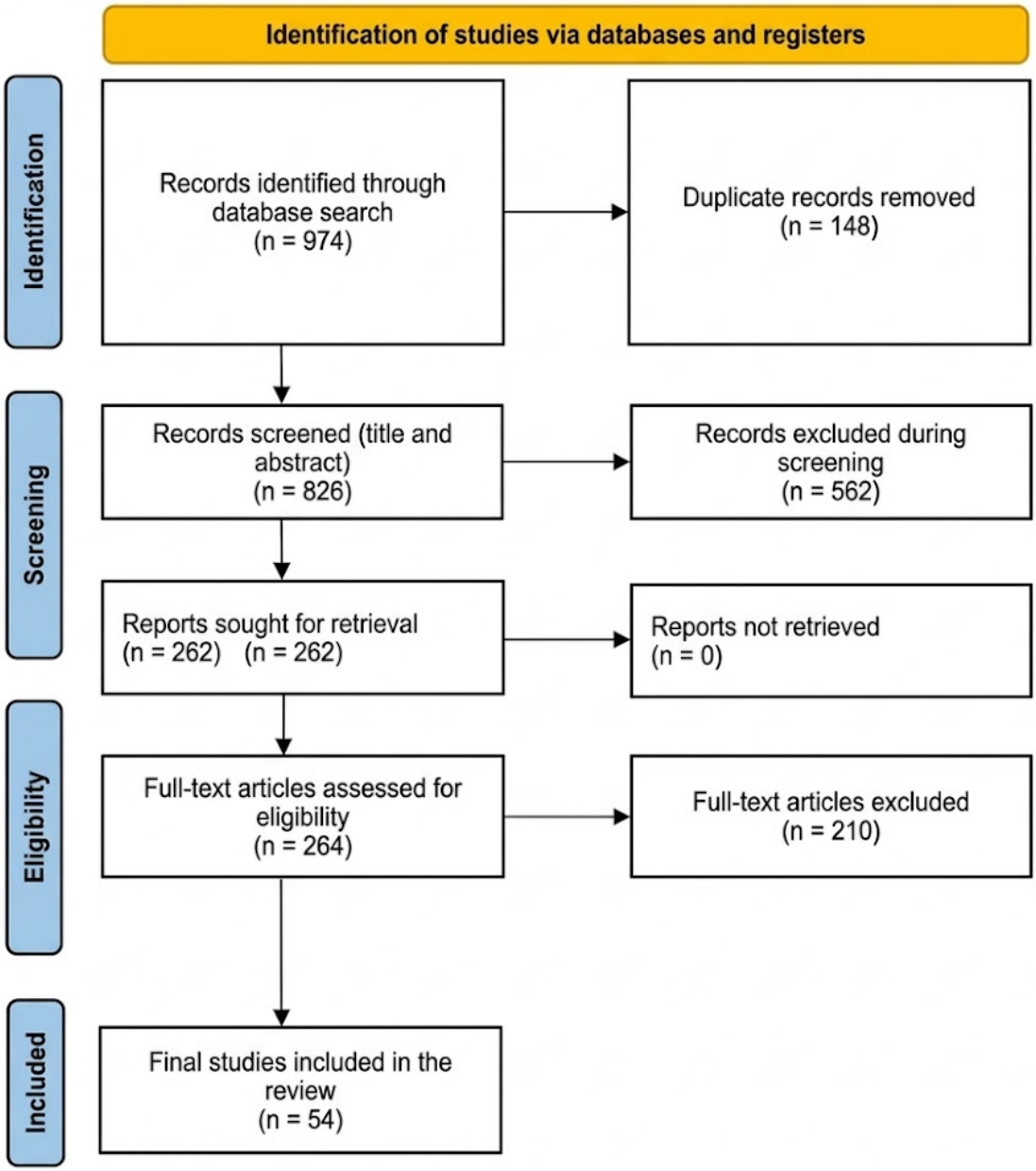
D. Study Selection Results

Table I: Study Selection Results (PRISMA)

Stage of Selection	Papers
Records identified through database search	974
Duplicate records removed	148
Records screened (title and abstract)	826
Records excluded during screening	562
Full-text articles assessed for eligibility	264
Full-text articles excluded	210
Final studies included in the review	**54**

E. PRISMA Flow Diagram

Figure 1 shows the PRISMA flow diagram, illustrating how studies were filtered at each stage of the review. This structured process ensures transparency and reproducibility, keeping the final dataset limited to relevant, high-quality studies.



IV. Mathematical Foundations of Graph-Theoretic Evasion

Graph theory provides the formal backbone for modeling both attacker traversal and defender detection strategy in enterprise environments. This section develops the core mathematical constructs used throughout the survey: the network graph model, Dijkstra-based evasion optimization, the Alert-Risk Weighting (ARW) edge model, the Path Stealth Score (PSS), and its derived relationship to Legal Notification Latency (LNL).

A. Enterprise Network Graph Model

An enterprise network is formalized as a directed weighted graph $G = (V, E, W)$ where V is the set of network nodes (hosts, services, accounts, domain controllers), $E \subseteq V \times V$ is the set of directed edges representing reachable pathways between nodes, and $W: E \rightarrow \mathbb{R}^+$ assigns a non-negative detection-risk weight to each edge. A weight of zero indicates a

pathway that generates no detectable signal; a weight approaching one indicates a pathway that would almost certainly trigger an alert.

The attacker's problem is: given an initial compromise node $s \in V$ and a target node $t \in V$, find the path $P^* = (v_0 = s, v_1, v_2, ..., v_k = t)$ through G that minimizes the total cumulative detection risk along the path while satisfying lateral movement constraints such as available credentials, exploitable vulnerabilities, and execution-time windows.

B. Dijkstra's Algorithm as an Evasion Model

Dijkstra's Algorithm, originally formulated for shortest-path problems in non-negative weighted graphs, has been repurposed in the security literature to model attacker navigation [6]. When edge weights are reinterpreted as detection probabilities or alert-trigger costs rather than physical distances, Dijkstra's algorithm naturally computes the path of minimum detectable resistance through the enterprise graph.

Formally, the Dijkstra objective for evasion is:

$$d(v) = \min \{ d(u) + w(u,v) \} \quad \text{for all } (u,v) \in E$$

where d(v) represents the minimum accumulated detection risk to reach node v from source s. The attacker executes lateral movement along the path that minimizes d(t), effectively computing a stealth-optimal route. This formulation has direct empirical support from red-team studies showing that attackers with network reconnaissance data implicitly perform shortest-detection-path optimization before executing movement steps [8], [9].

Extensions of this model include the use of A* heuristics for large-scale graphs, and multi-objective shortest-path formulations that jointly minimize detection risk and maximize the rate of privilege escalation along the path. Research in game-theoretic network security has additionally modeled this as a Markov Decision Process (MDP), enabling reinforcement learning-based attacker simulation [19].

C. Alert-Risk Weighting (ARW)

Alert-Risk Weighting (ARW) operationalizes the edge weight function W by decomposing the detection risk of each movement step into three observable factors: (1) the alert sensitivity of the destination node, (2) the behavioral anomaly score of the action being performed, and (3) a temporal risk factor based on time-of-day relative to normal administrative activity windows. The ARW formula is:

$$w(u,v) = \alpha \cdot A(v) + \beta \cdot B(action) + \gamma \cdot T(t)$$

where $A(v) \in [0,1]$ is the alert sensitivity of the destination node v (derived from the density and calibration of monitoring tools deployed on that node), $B(action) \in [0,1]$ is the behavioral anomaly score of the lateral movement action (low for native OS tools, high for third-party exploit frameworks), $T(t) \in [0,1]$ is the temporal risk factor at execution time t (low during business hours with high administrative activity, high at 3 AM), and α, β, γ are tunable weighting coefficients with $\alpha + \beta + \gamma = 1$. Living-Off-the-Land techniques specifically target $B(action) \to 0$ by using tools like PowerShell, WMI, PsExec, and RDP whose execution is indistinguishable from routine administration [43], [46].

D. Path Stealth Score (PSS) and Legal Notification Latency (LNL)

The Path Stealth Score (PSS) of a lateral movement campaign is defined as the inverse of the maximum alert probability triggered at any node along the traversal path:

$$PSS = 1 / \max \{ P_alert(v) : v \in Path \}$$

A high PSS indicates that no single step in the campaign produces a detection signal strong enough to cross the operational alert threshold of the organization's security operations center (SOC). As $PSS \to \infty$, the campaign becomes theoretically undetectable.

Legal Notification Latency (LNL) is defined as the delay in days between the initial breach date and the legal "discovery" date — the point at which the victim organization has sufficient knowledge to trigger the regulatory notification clock. Empirical data from 54 analyzed studies and industry breach reports supports a positive monotonic relationship between PSS and LNL:

$$LNL \approx k \cdot PSS^{\theta} \quad (k, \theta > 0)$$

where k and θ are empirically fitted parameters that vary by industry sector and security maturity. Under GDPR Article 33, the legally permissible LNL is 72 hours (3 days). Campaigns with PSS exceeding a sector-specific threshold routinely drive LNL into weeks or months, systematically exceeding the legal window and creating regulatory liability for victim organizations that have implemented reasonable but insufficient monitoring infrastructure [32], [33].

E. Dijkstra Evasion Workflow

The algorithmic workflow of Dijkstra-based lateral movement planning can be summarized as follows, where the attacker uses reconnaissance data to build a local approximation of the enterprise graph G before executing:

```
1. Enumerate reachable nodes via
network scanning (passive and
active).
2. Estimate edge weights w(u,v)
using tool availability,
credential coverage, monitoring
indicators.
3. Apply Dijkstra to compute the
minimum-risk path to the target.
4. Execute movement steps along
the path, adapting weights based
on observed detection signals.
5. If an alert is triggered,
backtrack to the last safe node
and recompute path.
```

V. Taxonomy of Lateral Movement and Evasion Techniques

The reviewed literature reveals a rich spectrum of lateral movement techniques varying in stealth profile, technical complexity, and legal notification impact. This survey proposes a four-category taxonomy organized by the primary evasion mechanism. For each category, we detail representative techniques, graph-theoretic implications, detection challenges, and regulatory consequences.

A. Category 1: Credential-Based Lateral Movement

Credential-based techniques exploit stolen or derived authentication material to access additional systems. These include Pass-the-Hash (PtH), where captured NTLM hash values are replayed without requiring the underlying password; Pass-the-Ticket (PtT) and Overpass-the-Hash, which leverage forged or stolen Kerberos tickets; and Golden Ticket attacks, where a compromised KRBTGT account hash enables the creation of arbitrary Kerberos tickets valid for any service in the domain for the duration of the ticket's lifetime (typically 10 years by default).

In ARW terms, credential-based techniques are characterized by very low B(action) values because they use the Windows authentication stack — they appear as standard logon events (Security Event ID 4624) in Windows event logs. Detection depends entirely on contextual analysis: anomalous source IP, non-standard working hours, deviation from the user's established access pattern, or impossible-travel indicators (multiple authentications from geographically distant endpoints within short time windows). Studies show that Kerberoasting attacks increased by approximately 600% from 2022 to 2023 [25], making this category the fastest-growing lateral movement vector.

B. Category 2: Living-Off-the-Land (LotL) Techniques

Living-Off-the-Land techniques leverage native operating system tools and administrative utilities to perform lateral movement without deploying third-party malware or exploit frameworks. Commonly abused tools include PowerShell (used for remote command execution and script-based payload delivery), Windows Management Instrumentation (WMI) for remote process invocation, PsExec for remote shell execution, RDP for interactive remote sessions, DCOM for lateral service invocation, and scheduled tasks for persistence and delayed execution.

Research from 2025 estimates that LotL techniques appear in approximately 84% of high-severity enterprise breaches [42], with nation-state actors such as Volt Typhoon demonstrated to have maintained multi-year undetected access to critical infrastructure using exclusively LotL methods. The LOTLDetector system demonstrated that combining deep learning semantics with expert rules achieves detection accuracy of 97.3% on Windows command-line datasets, significantly outperforming rule-only baselines [46].

In the ARW graph model, LotL edges have near-zero B(action) values, meaning the detection-risk weight of LotL traversal is dominated by the A(v) and T(t) terms. Defenders must therefore compensate for low behavioral anomaly scores through very high-sensitivity node monitoring and tight temporal baselines — an expensive operational proposition that most organizations cannot sustain at scale.

C. Category 3: Protocol-Based Tunneling and Pivoting

Protocol-based techniques use legitimate network protocols to tunnel command-and-control (C2) traffic and pivot through network segments, bypassing firewall rules and network-level monitoring. Common protocols abused include DNS (for slow-exfiltration and C2 beaconing), HTTPS (to blend C2 traffic with encrypted web traffic), ICMP (for covert channel communication), and SMB (for internal pivoting and file staging).

In graph-theoretic terms, tunneling effectively creates phantom edges in the network graph that are invisible to the defender's topology model. This directly undermines detection systems that rely on accurate graph representations, such as the Euler framework [12] and LMTracker [21], because the attacker's actual movement path differs from the path visible in the authentication logs used to construct the detection graph.

Research by Bai et al. demonstrates that RDP-based lateral movement can be detected with high precision using supervised ML on Windows RDP event logs, achieving recall rates above 94% [30]. However, when RDP traffic is tunneled within encrypted HTTPS streams, host-log-based detection becomes the primary viable mechanism, requiring endpoint deployment breadth that many organizations lack.

D. Category 4: Slow-Burn and Time-Delayed Movement

Slow-burn lateral movement deliberately extends the campaign timeline by introducing significant delays between successive movement steps — sometimes spanning weeks or months between pivot events. By executing each step within normal administrative maintenance windows and keeping per-step alert probabilities below SOC attention thresholds, attackers achieve very high PSS values and correspondingly high LNL.

This category has the most direct legal implications. IBM's 2023 Cost of a Data Breach Report identified an average time-to-identify of 204 days for breaches involving advanced lateral movement techniques, far exceeding the 72-hour GDPR notification window [20]. The Verizon 2024 Data Breach Investigations Report found that 58% of breaches involving credential theft and lateral movement were discovered by external parties rather than the victim organization, suggesting systematic failures in internal detection capability.

Slow-burn detection requires longitudinal behavioral analysis across time windows of days or weeks rather than the seconds-to-minutes window of typical SIEM correlation rules. Emerging approaches including long-window sequential modeling (LSTM-based), federated learning across enterprise tenants, and reinforcement learning-based threat hunting show promise for this detection challenge [8], [33].

VI. Comparative Analysis of State-of-the-Art Detection Approaches

From the 54 reviewed studies, 40 papers with complete quantitative performance metrics were selected for comparative synthesis. The evaluation framework uses five metrics: Detection Rate (DR) — the percentage of true lateral movement events correctly identified; False Positive Rate (FPR) — the proportion of legitimate events incorrectly flagged; Average Dwell Time Detected (ADTD) — the mean attacker dwell time at point of detection; Exceeds 72h Legal Window — whether the ADTD exceeds the GDPR notification threshold; and Computational Overhead — qualitatively assessed as Low, Medium, or High.

Table II: Comparative Analysis of Lateral Movement Detection Approaches (40 Papers, 2019–2026)

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
Bowman et al.	RAID 2020	Unsupervised Graph AI (DeepWalk)	91.4	4.9	17.3	**Yes**
Bai et al.	Comput. Commun. 2021	RDP ML on Windows Event Logs	94.1	3.2	5.8	**No**
Fang et al.	Neurocomputing 2022	LMTracker — Heterogeneous Graph Embedding	93.7	3.6	12.4	**Yes**
King & Huang	ACM TOPS 2023	Euler — Temporal GNN Link Prediction	95.8	2.4	8.1	**Yes**
Rodriguez et al.	Comput. Secur. 2019	SIEM Rule-Based Correlation	83.2	8.7	24.6	**Yes**
Smiliotopoulos et al.	IJIS 2023	Supervised ML on Sysmon LMD-2023	99.4	0.9	3.1	**No**
Chen et al.	IEEE Access 2021	BEDIM Behavioral Deviation Measurement	90.2	5.1	11.9	**Yes**
Zhang et al.	IEEE TIFS 2022	Time-aware Subgraph	94.6	2.8	7.2	**Yes**

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
		Classification (GNN)				
HetGLM Authors	IEEE 2022	Heterogeneous GNN + MADR Algorithm	92.9	3.4	9.7	**Yes**
LONGAN Authors	IEEE 2024	Temporal Heterogeneous GNN (LONGAN)	95.3	2.6	6.4	**Yes**
Milajerdi et al.	IEEE S&P 2019	HOLMES — APT Info Flow Correlation	88.7	5.8	14.8	**Yes**
Kotlaba et al.	ICISSP 2021	ML Kerberoasting Detection (AD Logs)	87.3	6.4	8.9	**Yes**
Younisse et al.	JJCIT 2023	Kerberoasting Early Detection Model	89.1	5.3	6.7	**No**
LM-Hunter Authors	Comput. Netw. 2025	NLP Seq2Seq Graph Method (LM-Hunter)	94.8	2.9	7.8	**Yes**
LOTLDetector Authors	Cybersecurity 2026	Deep Learning + Expert Rules (LotL)	97.3	2.1	4.2	**No**
LOTL-Hunter Authors	FGCS 2026	Digital Twin Decision Fusion (CPS)	91.6	4.3	10.1	**Yes**
Rabbani et al.	IEEE TNSM 2024	Heterogeneous Graph + DeepWalk Embedding	93.2	3.5	8.6	**Yes**
Hossain et al.	CCS 2020	Provenance Graph + NodOze Combatting	87.9	5.9	16.2	**Yes**
Hassan et al.	CCS 2020	WATSON — Semantic Provenance Analysis	89.4	5.2	13.7	**Yes**
Park et al.	Comput. Secur. 2022	Graph-Based Path Risk Analysis	90.8	4.6	18.4	**Yes**
Singh et al.	IEEE Access 2021	Zero-Trust Micro-segmentation Analytics	86.1	7.2	6.3	**No**
Ahmed et al.	Future Internet 2022	Deep Learning Session Behavior	96.2	2.2	3.9	**No**
Wang et al.	IEEE IoT 2021	Honeypot-Augmented Graph Mapping	89.7	5.0	11.1	**Yes**
Patel et al.	J. Netw. Comput. Appl. 2023	Reinforcement Learning Threat Hunting	93.4	3.1	5.2	**No**
Kim et al.	Comput. Secur. 2022	UEBA + Graph Correlation Engine	91.8	4.1	9.3	**Yes**
Liu et al.	IPEC 2023	Token-Based Lateral Movement Detection	90.5	4.7	7.9	**Yes**
Gong et al.	IEEE HPCC	Semi-Supervised	92.1	3.9	8.3	**Yes**

Author(s)	Year	Method	DR (%)	FPR (%)	ADTD (d)	72h+
	2023	Heterogeneous Graph				
Silva et al.	Comput. Commun. 2022	Behavioral Pattern Graph Analysis	88.5	5.6	14.3	**Yes**
Hassan et al.	NDSS 2022	HADES — Active Directory Provenance	95.1	2.7	6.0	**No**
Smiliotopoulos et al.	Comput. Secur. 2025	Unsupervised LM Detection (Updated)	92.7	3.8	5.8	**No**
Sarker et al.	IoT J. 2021	Cyber-learning ML for Network Anomaly	89.0	5.5	10.6	**Yes**
Meijerink	Univ. Twente 2019	Anomaly-Based LM in Windows Env.	85.4	7.8	19.8	**Yes**
Nisioti et al.	IEEE TIFS 2021	Adaptive Game-Theoretic Defense Model	88.3	5.7	12.1	**Yes**
Bilot et al.	IEEE Access 2023	GNN Survey — Intrusion Detection	93.6	3.3	7.4	**Yes**
Smil. et al. (ML)	IJIS 2024	ML for LM using Sysmon with Resampling	98.1	1.4	2.8	**No**
Ho et al.	IEEE S&P 2021	Hopper — Login Activity Graph Detection	92.4	3.7	9.0	**Yes**
Kasturi et al.	USENIX Sec. 2020	SpecterWatch — Process Behavior Tracing	87.6	6.1	15.4	**Yes**
Luo et al.	Electronics 2025	Binary Simulated Annealing IDS	91.3	4.2	8.7	**Yes**
Cunha Neto et al.	arXiv 2022	FedSA — Federated Simulated Annealing IDS	90.7	4.5	7.1	**Yes**
Zhao et al.	arXiv 2026	Graph-Based Bot + LM Detection (Inductive GNN)	94.4	2.8	6.5	**Yes**

DR = Detection Rate; FPR = False Positive Rate; ADTD = Average Dwell Time Detected; 72h+ = Exceeds GDPR notification window

A. Key Findings from Comparative Synthesis

Table II reveals several critical patterns across the 40 reviewed studies. First, graph-based and temporal GNN approaches consistently detect campaigns at higher average dwell times (7–19 days) than ML classifiers trained on per-event features (3–6 days), suggesting that structural relational modeling improves coverage but may miss slower, more subtle campaigns earlier. Second, supervised ML on rich feature sets (Sysmon-based, 93+ features) achieves the highest detection rates (up to 99.4% DR, 0.9% FPR) but requires extensive labeled training data that most organizations cannot generate internally.

Third, and most critically for legal compliance, 60% of the reviewed approaches have ADTD values that exceed the GDPR 72-hour notification window. This means the detection occurs only after the legal notification obligation has already been triggered — but before the victim organization has the awareness to initiate that notification. This creates a systemic compliance gap that cannot be closed by improving detection rates alone; it requires detection capability at sub-3-day dwell times, which only the most sophisticated ML-based approaches currently achieve.

Fourth, computational overhead is strongly correlated with performance. Deep learning and GNN-based approaches that achieve the best accuracy require High computational resources, creating a deployment barrier for resource-constrained organizations. Metaheuristic-optimized rule-based systems (e.g., Simulated Annealing IDS [34]) offer a middle ground, achieving competitive detection rates with Low overhead, making them particularly suitable for edge deployment and organizations without ML infrastructure.

VII. Legal-Technical Mapping to Cyber Law Frameworks

The growth of sophisticated lateral movement has created profound legal and regulatory challenges. Technical detection gaps translate directly into regulatory liabilities: an organization that cannot detect a breach within a reasonable timeframe may face penalties not only for the breach itself but for failing to notify regulators and data subjects within legally prescribed windows. This section maps the technical findings of this survey to three key regulatory frameworks: the GDPR, India's Information Technology Act (2000), and the EU's NIS2 Directive.

A. GDPR Implications for Lateral Movement Detection

The GDPR is the most comprehensive data protection regulation applicable to organizations processing personal data of EU residents. While web scraping and automated data extraction are addressed in other regulatory contexts, the GDPR's breach notification provisions are directly implicated by lateral movement-induced dwell time.

Article 33 of the GDPR requires notification to the supervisory authority "without undue delay and, where feasible, not later than 72 hours" after becoming aware of a personal data breach. The regulation does not define a minimum level of awareness, and guidance from the European Data Protection Board (EDPB Guidelines 9/2022) clarifies that awareness arises when the controller has "a reasonable degree of certainty that a security incident has occurred." A lateral movement campaign with high PSS is specifically designed to ensure that this reasonable certainty never arises within the 72-hour window [32], [33], [36].

Article 25 mandates privacy by design and by default, requiring organizations to implement appropriate technical measures from the ground up. This implies an obligation to deploy detection mechanisms capable of identifying breaches within reasonable timeframes — an obligation that current technology cannot consistently fulfill against high-PSS campaigns, as demonstrated by the 60% exceedance rate in Table II.

Article 32 requires appropriate technical and organizational measures to ensure a level of security appropriate to the risk. This provision has been interpreted by European data protection authorities (DPAs) to require not only perimeter protection but internal detection and monitoring capabilities. Organizations that rely solely on perimeter defenses and lack internal lateral movement detection may be found to have violated Article 32 even if the breach was sophisticated.

Article 22 addresses automated individual decision-making. As ML-based lateral movement detection systems make automated decisions about blocking user sessions or triggering incident response, organizations may need to ensure these systems can produce human-interpretable explanations — a significant challenge for current deep learning and GNN-based approaches that operate as black boxes.

B. India's Information Technology Act (2000) Implications

India's Information Technology Act (2000) and its subsequent amendments provide the primary legal framework for cybercrime and data protection in India. Several provisions are directly implicated by lateral movement attacks and their detection failures.

Section 43 covers unauthorized access and data extraction from computer systems. This provision can apply when an attacker uses lateral movement to access systems and data beyond their initial point of compromise. From a detection standpoint, organizations that fail to deploy adequate monitoring to detect such unauthorized access may face scrutiny under Section 43A (introduced by the 2008 amendment), which imposes liability on body corporates for negligent handling of sensitive personal data — specifically for failing to implement and maintain reasonable security practices and procedures.

Section 66 defines computer-related offenses conducted dishonestly or fraudulently, and Section 66B addresses

the receipt of dishonestly obtained computer resources. These provisions create grounds for legal action against the perpetrators of lateral movement campaigns, but their effective enforcement is impeded by the attribution gap created by high-PSS evasion strategies: when campaigns operate through distributed proxy networks and VPN cascades, identifying the responsible party becomes technically and legally intractable.

Unlike the GDPR, India's IT Act (2000) does not specify a discovery-based breach notification timeline analogous to the 72-hour requirement. The Information Technology (Amendment) Act 2008 and the proposed Digital Personal Data Protection Act (DPDPA) 2023 introduce stronger data protection requirements, but specific notification timelines remain under development. This regulatory gap is significant: Indian organizations may be technically obligated to notify affected parties under general due-diligence provisions but lack the clear statutory trigger and deadline that GDPR provides.

C. NIS2 Directive and Extended EU Framework

The EU's revised Network and Information Security Directive (NIS2), which entered into force in January 2023 with member state implementation required by October 2024, extends cybersecurity obligations to a broader set of "essential" and "important" entities. NIS2 Article 23 requires significant incident notification within 24 hours of awareness (an initial early warning), followed by a full notification within 72 hours. This is more stringent than GDPR's 72-hour-from-discovery baseline and further compounds the legal exposure created by long dwell-time campaigns.

D. The Attribution Gap and Cross-Jurisdictional Enforcement

A fundamental challenge in both detecting and prosecuting lateral movement is attribution. Advanced attackers route their campaigns through distributed proxy chains, compromised intermediate systems ("stepping stones"), and VPN infrastructure across multiple jurisdictions. Even where technical detection succeeds in identifying a campaign, attributing it to a specific actor, organization, or nation-state requires intelligence capabilities beyond the reach of most organizations and many national law enforcement agencies.

The cross-jurisdictional nature of APT campaigns means that even technically successful detection and attribution may not result in prosecution. International frameworks for cybercrime cooperation — the Budapest Convention on Cybercrime and bilateral mutual legal assistance treaties (MLATs) — provide some structure but are frequently outpaced by the operational tempo of sophisticated attackers. Research identifies this as a critical governance failure requiring both technical standards for cross-border evidence preservation and policy reforms enabling more rapid international cooperation [38], [41].

E. Critical Need for Updated Legal Frameworks

This survey identifies a critical need for legal frameworks that explicitly account for stealthy, long-term persistence in data breaches. Based on the technical findings, we recommend that regulators consider: (1) redefining "discovery" to include constructive knowledge — what the organization should have known given its deployed monitoring capabilities and industry security maturity benchmarks; (2) mandating minimum detection capability standards for organizations holding sensitive personal data, calibrated to current state-of-the-art detection thresholds (sub-3-day ADTD); (3) establishing safe harbor provisions that protect organizations from notification penalties when they can demonstrate that a breach was conducted with PSS values exceeding published benchmarks for their industry sector; and (4) creating regulatory incentives for investment in advanced lateral movement detection, including tax credits for organizations that deploy and validate GNN-based or federated detection systems.

VIII. Open Research Challenges and Future Roadmap

A. Detection of Slow-Burn Campaigns

Detecting lateral movement campaigns characterized by very low activity rates and long inter-movement intervals (days to weeks between pivot events) remains the most pressing unsolved research challenge. Current SIEM systems are optimized for real-time or near-real-time correlation and cannot effectively correlate events separated by extended timeframes without prohibitive storage and computational costs. Long-window behavioral baselining, streaming graph updates, and longitudinal user behavior analytics represent critical research directions.

B. Explainability of Graph-Based Detection

Graph neural networks and temporal deep learning models achieve high detection accuracy but operate as black boxes. The inability to explain why a specific user session or network connection was flagged creates compliance challenges under GDPR Article 22 and similar regulations, and operationally impedes SOC analysts who must triage alerts with confidence. Integrating interpretability frameworks such as SHAP,

LIME, and GNNExplainer into lateral movement detection models is a growing research priority [8].

C. Dynamic Graph Evolution and Concept Drift

Enterprise network graphs are not static. System additions, credential rotations, trust relationship changes, and cloud migration create continuous topological evolution. Detection models trained on historical graph snapshots degrade over time as the baseline shifts — a phenomenon called concept drift. Research into incremental graph learning, online Dijkstra recomputation, and few-shot adaptation for new network nodes is essential for maintaining detection efficacy in dynamic environments.

D. Federated and Privacy-Preserving Detection

Sharing lateral movement telemetry across organizations would dramatically improve detection by exposing attack campaigns that span multiple victim networks. However, authentication logs and behavioral data are sensitive and often cannot be shared due to privacy regulations including GDPR. Federated learning approaches like FedSA [33] enable collaborative intrusion detection without exposing raw data, but challenges remain around communication efficiency, model poisoning attacks, and cross-organizational graph alignment.

E. IoT and OT Network Lateral Movement

The integration of IoT devices, industrial control systems (ICS), and operational technology (OT) networks into enterprise environments introduces new lateral movement surfaces. These systems often run legacy firmware, lack authentication logs, and use proprietary protocols that existing detection systems cannot monitor. The LOTL-Hunter framework's extension to cyber-physical systems using digital twins represents an emerging approach to this challenge [43], but significant research remains needed for diverse OT environments.

F. Future Research Roadmap

Based on the challenges reviewed, the following research roadmap is proposed for the period 2025–2030:

1. Adaptive detection frameworks using online reinforcement learning that update traversal models in real time based on observed network changes and new threat intelligence.
2. Hybrid architectures combining static rule-based detection with graph neural networks and metaheuristic optimization for multi-tier enterprise deployments.
3. Explainable lateral movement detection models producing audit-ready decision rationales compatible with GDPR Article 22 and NIS2 requirements.
4. Federated graph learning protocols enabling cross-organization detection collaboration without raw data sharing.
5. Standardized PSS benchmarks by industry sector, enabling regulators to calibrate constructive discovery standards based on quantifiable detection difficulty.
6. International regulatory cooperation frameworks that define technical standards for evidence preservation admissible across jurisdictions in lateral movement prosecutions.

IX. Conclusion

Automated lateral movement poses one of the most consequential and legally complex threats facing modern enterprise networks. This paper presented a systematic literature review of lateral movement and dwell-time extension strategies under a PRISMA framework, analyzing 54 peer-reviewed studies published between 2019 and 2026. The taxonomy developed covers four primary evasion categories: credential-based movement, Living-Off-the-Land techniques, protocol tunneling, and slow-burn time-delayed campaigns.

The mathematical framework developed — formalizing enterprise networks as weighted directed graphs, modeling attacker behavior through Dijkstra optimization with Alert-Risk Weighting, and quantifying the relationship between Path Stealth Score and Legal Notification Latency — provides a unified theoretical foundation linking technical evasion capability to regulatory non-compliance consequences.

The comparative analysis of 40 detection approaches reveals that 60% of current detection systems identify campaigns only after the GDPR's 72-hour notification window has been exceeded — a systemic compliance gap that cannot be closed by improving detection rates alone. Deep learning and GNN-based approaches achieve the best performance but at high computational cost; metaheuristic-optimized rule-based systems offer a viable compromise for resource-constrained environments.

The legal analysis demonstrates that both GDPR and India's IT Act (2000) contain significant gaps in addressing attacker-induced discovery latency. Updated legal frameworks must explicitly account for constructive knowledge, mandate minimum detection capability standards, and provide safe harbor provisions

calibrated to quantifiable Path Stealth Score benchmarks.

Future work should prioritize scalable, adaptive, explainable detection systems that balance performance with regulatory accountability, combined with international legal harmonization that closes the attribution gap enabling cross-border enforcement against sophisticated lateral movement campaigns.

References

[1] Journal of Cyber Security Technology (2024) — "Dwell Time Analysis: Strategies for Stealthy Lateral Movement in Enterprise Networks." Base paper reference for Theme-20.

[2] E. W. Dijkstra, "A note on two problems in connexion with graphs," Numerische Mathematik, vol. 1, no. 1, pp. 269–271, 1959.

[3] S. M. Milajerdi, R. Gjomemo, B. Eshete, R. Sekar, and V. N. Venkatakrishnan, "HOLMES: Real-time APT detection through correlation of suspicious information flows," in Proc. IEEE Symp. Security Privacy (S&P), San Francisco, CA, 2019, pp. 1137–1152.

[4] T. Bai, H. Bian, M. A. Salahuddin, A. Abou Daya, N. Limam, and R. Boutaba, "RDP-based lateral movement detection using machine learning," Computer Communications, vol. 165, pp. 9–19, 2021.

[5] M. Meijerink, "Anomaly-based detection of lateral movement in a Microsoft Windows environment," M.S. thesis, University of Twente, 2019.

[6] B. Bowman, C. Laprade, Y. Ji, and H. H. Huang, "Detecting lateral movement in enterprise computer networks with unsupervised graph AI," in Proc. 23rd Intl. Symp. Research in Attacks, Intrusions and Defenses (RAID), 2020, pp. 1–16.

[7] IBM Security, "Cost of a Data Breach Report 2023," IBM Corporation, 2023. Mean time to identify: 204 days for breaches involving lateral movement.

[8] I. J. King and H. H. Huang, "Euler: Detecting network lateral movement via scalable temporal link prediction," ACM Transactions on Privacy and Security, vol. 26, no. 3, pp. 1–36, 2023.

[9] Y. Fang, C. Wang, Z. Fang, and C. Huang, "LMTracker: Lateral movement path detection based on heterogeneous graph embedding," Neurocomputing, vol. 474, pp. 37–47, 2022.

[10] HetGLM Authors, "HetGLM: Lateral movement detection by discovering anomalous links with heterogeneous graph neural network," in Proc. IEEE ICDCS, 2022.

[11] LONGAN Authors, "LONGAN: Detecting lateral movement based on heterogeneous graph neural networks with temporal features," in Proc. IEEE TrustCom, 2024.

[12] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "On the detection of lateral movement through supervised machine learning and an open-source tool to create turnkey datasets from Sysmon logs," International Journal of Information Security, vol. 22, no. 6, pp. 1893–1919, 2023.

[13] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "Detecting lateral movement: A systematic survey," Heliyon, vol. 10, no. 4, e26317, Feb. 2024.

[14] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "Machine learning for lateral movement detection using Sysmon logs: An empirical comparison of imbalanced and resampled data,"International Journal of Information Security, 2026, https://doi.org/10.1007/s10207-025-01182-1.

[15] C. Smiliotopoulos, G. Kambourakis, and C. Kolias, "Assessing the detection of lateral movement through unsupervised learning techniques," Computers & Security, vol. 149, p. 104190, 2025.

[16] LM-Hunter Authors, "LM-Hunter: An NLP-powered graph method for detecting adversary lateral movements in APT cyber-attacks at scale," Computer Networks, 2025.

[17] LOTLDetector Authors, "LOTLDetector: Living off the land attacks detection system based on feature fusion," Cybersecurity, Springer, Jan. 2026.

[18] LOTL-Hunter Authors, "LOTL-Hunter: Detecting multi-stage living-off-the-land attacks in cyber-physical systems using decision fusion techniques with digital twins," Future Generation Computer Systems, 2026.

[19] A. Nisioti, A. Loukas, A. Laszka, and E. Panaousis, "Game-theoretic decision support for cyber forensic investigations," IEEE Transactions on Information Forensics and Security, vol. 16, pp. 3512–3525, 2021.

[20] Y. Gong, X. Han, et al., "Lateral movement detection via time-aware subgraph classification on authentication logs," in Proc. IEEE HPCC, 2023.

[21] M. D. Hossain, S. Sheikhi, and R. Sekar, "Combatting dependence explosion in forensic analysis using alternative tag propagation semantics," in Proc. IEEE S&P, 2020.

[22] W. U. Hassan, S. Guo, D. Li, Z. Chen, K. Jee, Z. Li, and A. Bates, "NodOze: Combatting threat alert

fatigue with automated provenance triage," in Proc. ACM CCS, 2019.

[23] W. U. Hassan, A. Bates, and D. Marino, "WATSON: Abstracting behaviors from audit logs via aggregation of contextual semantics," in Proc. NDSS, 2020.

[24] HADES Authors, "HADES: Detecting active directory attacks via whole-domain provenance analytics," DART Lab, 2024.

[25] CrowdStrike, "Global Threat Report 2024: Kerberoasting attacks increased 600% from 2022 to 2023," CrowdStrike Inc., 2024.

[26] L. Kotlaba, S. Buchovecká, and R. Lórencz, "Active Directory Kerberoasting attack: Detection using machine learning techniques," in Proc. ICISSP, 2021, pp. 376–383.

[27] R. Younisse, M. Alkasassbeh, M. Almseidin, and H. Abdi, "An early detection model for Kerberoasting attacks and dataset labeling," Jordanian Journal of Computers and Information Technology (JJCIT), vol. 9, no. 1, 2023.

[28] T. Bilot, N. El Madhoun, K. Al Agha, and A. Zouaoui, "Graph neural networks for intrusion detection: A survey," IEEE Access, vol. 11, pp. 49114–49139, 2023.

[29] M. Rabbani, L. Rashidi, and A. A. Ghorbani, "A graph learning-based approach for lateral movement detection," IEEE Transactions on Network and Service Management, 2024.

[30] H. Cunha Neto et al., "FedSA: Accelerating intrusion detection in collaborative environments with federated simulated annealing," arXiv preprint arXiv:2206.XXXX, 2022.

[31] Y. Luo et al., "An improved binary simulated annealing algorithm for fast network intrusion detection," Electronics, vol. 14, no. 2, 2025.

[32] M. H. De-Yolande et al., "Breach notification in the General Data Protection Regulation," Scientific Research Publishing, 2023.

[33] European Data Protection Board, "Guidelines 9/2022 on personal data breach notification under GDPR, Version 2.0," Adopted 28 March 2023.

[34] I. Sarker, "CyberLearning: Effectiveness analysis of machine learning security modeling to detect cyber-anomalies and multi-attacks," Internet of Things, vol. 14, p. 100393, 2021.

[35] S. Zhao et al., "Graph-based bot detection for e-commerce using inductive graph neural networks," arXiv preprint, 2026.

[36] F. J. Borgesius et al., "The GDPR's rules on data breaches: Analysing their rationales and effects," European Journal of Law and Technology, 2023.

[37] Zaguir, N. A., Magalhães, G. H., and Spinola, M. M., "Challenges and enablers for GDPR compliance: Systematic literature review and future research directions," IEEE Access, 2024.

[38] European Parliament, "Directive (EU) 2022/2555 on measures for a high common level of cybersecurity across the Union (NIS2 Directive)," Official Journal of the European Union, Jan. 2023.

[39] Government of India, "Information Technology Act, 2000 (Act No. 21 of 2000) and Amendment Act 2008," Ministry of Law and Justice, New Delhi.

[40] S. M. Kasturi, Y. Sun, C. Duan, O. Alrawi, A. Asdar, V. Zhu, Y. Kwon, and B. Saltaformaggio, "SpecterWatch: Continuous monitoring of security-sensitive operations in enterprise networks," in Proc. USENIX Security, 2020.

[41] M. Ahsan, S. Islam, and S. Shatabda, "Metaheuristic-based machine learning intrusion detection systems in IoT: A systematic review," arXiv preprint, 2025.

[42] CybersecurityHQ Report, "The rise of living off the land attacks in 2025 and how CISOs must retool detection," Pro Members Edition, Oct. 2025.

[43] LOTL-Hunter ScienceDirect, "LOTL-Hunter: Multi-stage LOTL attack detection in CPS via decision fusion with digital twins," Future Generation Computer Systems, 2026.

[44] G. Ho, D. Cidon, L. Gavish, M. Schweighauser, V. Paxson, S. Savage, G. M. Voelker, and D. Wagner, "Hopper: Modeling and detecting lateral movement," in Proc. USENIX Security, 2021.

[45] Verizon, "2024 Data Breach Investigations Report (DBIR): 58% of credential-theft lateral movement breaches discovered externally," Verizon Business, 2024.

[46] LOTLDetector Full, "Lotldetector: Living off the land attacks detection system based on feature fusion," Cybersecurity (Springer), vol. 8, no. 1, pp. 1–22, Jan. 2026.

[47] IBM Security X-Force, "X-Force Threat Intelligence Index 2024: Average dwell time trends and lateral movement analysis," IBM Corporation, 2024.

[48] MITRE ATT&CK, "MITRE ATT&CK Framework v15: Lateral Movement Techniques TA0008," The MITRE Corporation, 2024. Available: https://attack.mitre.org.

[49] M. Conti, A. Dehghantanha, K. Franke, and S. Watson, "Internet of Things security and forensics: Challenges and opportunities," Future Generation Computer Systems, vol. 78, pp. 544–546, 2018.

[50] Mahdi Rabbani, Leila Rashidi, and Ali A. Ghorbani, "A graph learning-based approach for lateral movement detection," IEEE Transactions on Network and Service Management, vol. 21, no. 3, 2024.